

SQL 判题考试系统——Q&A 问题库

第三组

2026 年 6 月 26 日

判题与安全

Q1: 判题引擎怎么保证安全？学生 SQL 会不会破坏数据库？

三层防护。第一层关键字黑名单，拦截 DROP、INSERT、DELETE、ALTER、TRUNCATE 等危险操作。第二层分号计数，不允许提交多语句；字符串里的分号不会误判。第三层 JSqlParser 做 AST 语法树解析，只允许 PlainSelect，UNION、INTERSECT、子查询里的 DML 都会被拒绝。执行时创建临时 MySQL schema，用完立刻在 finally 块里删掉，跟业务库完全物理隔离。还设了 5 秒超时和 1000 行返回上限。

Q2: JSqlParser 如果被绕过怎么办？比如用注释或者编码隐藏关键字？

关键字检测在实际解析之后的 AST 节点上做，不是简单的字符串匹配，注释和编码混淆在语法树阶段已经被剥离了。退一步说，就算绕过了第三层，第一层的 MySQL 权限是低权限账号，只能操作临时 schema，影响不了业务库。

Q3: 为什么不把判题放到 Docker 容器里做？

设计文档里写了，Docker 沙箱是后续扩展方向。MVP 阶段用临时 schema 隔离，方案更轻量，部署依赖少，对于课程项目的规模完全够用。后续如果要支持 DML 类题目或者更高的并发量，再引入容器隔离加消息队列异步判题。

Q4: 结果比对的时候，列顺序和行顺序怎么处理的？

列名必须严格匹配，但默认不区分大小写。行顺序在测试用例里有个 orderSensitive 字段，如果是 false 就把两边的行排序后比较。数字类型做了规范化，1 和 1.0 视为相等。NULL 必须跟 NULL 匹配，不能用空字符串替代。结果先转成规范化的 JSON 格式再逐项比较。

功能与设计

Q5: 为什么第一版只支持 SELECT，不支持 INSERT、UPDATE？

两个原因。一是安全——DML 操作的破坏风险更大，判题完后回滚或清理数据的

复杂度高很多。二是结果比对——SELECT 只要比较查询结果集，DML 题目需要比对表状态的变化，比对维度和规则都不一样。设计文档 7.1 节明确写了 MVP 判题范围是查询类题目，后续扩展需要单独设计 DML 的执行策略和比对方式。

Q6：考试怎么防止学生在浏览器里查答案或者切出去查资料？

目前考试有个 `lockdownEnabled` 开关，但 MVP 阶段主要靠考试时间窗口和时长限制来约束。严格的反作弊——比如全屏锁定、切屏检测、IP 监控——涉及到浏览器层面的能力，属于后续扩展。核心保障是成绩计算由服务端完成，前端只负责展示。

Q7：考试的成绩是怎么算的？能不能被前端篡改？

每道题的考试提交独立判分，取该题所有提交里的最高分。考试的最终成绩由服务端按 SUM（每题最高分）自动汇总，写入 `exam_students.final_score`。前端只能调用接口触发重新计算，不能直接传入分数值，所以无法篡改。

Q8：题目被删了以后，历史提交记录怎么办？

题目用的是软删除——`visible = 0`，不是物理删除。所以历史提交记录的外键关联不会断，成绩统计和提交历史都能正常展示。学生看不到已删除的题目，但教师和管理员可以在提交记录里追溯到。

架构与技术

Q9：为什么用 MyBatis 而不是 JPA？

SQL 判题系统的很多查询——比如统计学生正确率、连续练习天数、成绩汇总——需要手写比较复杂的 SQL。MyBatis 对 SQL 的可控性更好，参数化查询也能保证防注入。设计文档 2.1 节选了 MyBatis，优先保证对数据库的精细控制。

Q10：前后端怎么处理权限的？只靠前端隐藏按钮够不够？

不够。前端只做显示控制——按角色展示不同的菜单和按钮。真正的权限校验在后端，每个核心接口都用 `@PreAuthorize` 注解标注了角色要求。即使学生直接调教师接口，后端也会返回 403。测试的时候把鉴权矩阵全部过了一遍，三种角色的每个接口都验证过。

Q11：数据库为什么用 Flyway 管理迁移？

9 张核心表加种子数据一共 4 个迁移脚本，Flyway 能保证每次部署的数据库结构一致，不会出现“你少一个字段我多一个索引”的问题。种子数据——三个默认账号、10 道 LeetCode 题——也通过迁移脚本自动导入，一键启动就能用。

项目总结

Q12: 这个项目跟 LeetCode 的数据库题有什么区别？

LeetCode 只有判题，没有教学管理功能。我们多了班级管理、考试发布、成绩统计、多角色权限控制，是一个完整的数据库课程教学闭环——学生练习、老师出题出考试、自动判题、成绩汇总。面向的是课堂场景，不是纯刷题。

Q13: 你们四个人怎么分工的？

(按实际情况回答)

Q14: 过程中遇到的最大困难是什么？

判题引擎的安全设计。最开始只用关键字黑名单，测试的时候发现 UNION 可以绕过单 SELECT 限制。后来引入了 JSqlParser 做 AST 级别的语法校验，才从根上堵住了。还有就是考试越权访问——学生能看到不是自己参加的考试——排查下来是后端只校验了登录状态，没校验考试和学生的关联关系。

Q15: 如果再做一版，哪些地方会改进？

第一，引入消息队列把判题异步化，现在的同步判题在高并发考试场景下撑不住。第二，Docker 沙箱替代临时 schema，同时支持 DML 题目。第三，补上助教的细粒度授权，目前助教角色只做了基本预留。第四，加审计日志，老师改分数、改题目、改考试都留痕。